



CAPSTONE PROJECT



AI Integration Strategy for Automated SQL Performance Tuning at a Global Financial Institution

Jurisdiction: Global Bank — Worldwide Operations

Sector: Financial Services | **Department:** IT / Database SRE

Prepared by: AI Strategy Division | **Date:** March 2026

Classification: Internal Use Only



Contents

- 1. Context3
 - Sector & Business Type.....3
 - Department, Process & Function3
 - Current vs. Future State.....4
 - Automated SQL Performance Tuning Pipeline.....5
- 2. Technology Choice6
 - Primary AI System: one of the top Frontier Models6
 - Supporting Technology Stack7
- 3. Cost Considerations8
 - Total Cost of Ownership — Year 1 Estimate8
 - Cost Optimisation Levers8
 - ROI Summary9
- 4. Security Plan..... 10
 - Govern & Identify 11
 - Protect..... 11
 - Detect, Respond & Recover 11
- 5. Change Management and Training 12
 - Stakeholder Communication Plan..... 12
 - Role-Based Training Programme 13
- 6. Scaling Strategy — Crawl, Walk, Run 14
 - Phase 1 — Crawl (Months 0–3): Advisory Only 15
 - Phase 2 — Walk (Months 3–6): Semi-Automated for Low-Risk SQL..... 15
 - Phase 3 — Run (Months 6–12+): Expanded Autonomous Operation..... 15
- 7. Governance and Compliance 16
 - Cross-Functional AI Oversight Committee 17
 - Applicable Regulatory Compliance Matrix 17
 - EU AI Act & SR 11-7 Classification..... 17
- 8. Key Performance Indicators (KPIs) 18
 - Monitoring & Review Cadence..... 19
 - What Success Looks Like 19

1. Context

Sector & Business Type

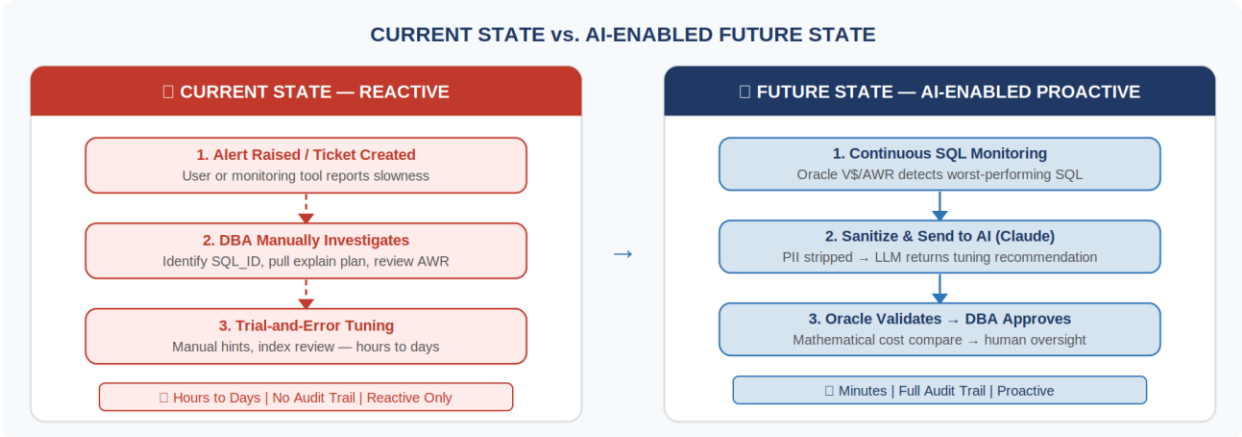
This initiative operates within a globally chartered financial institution (the "Bank") engaged in retail and wholesale banking, investment services, and enterprise payments. The Bank maintains operations across the United States, European Union, United Kingdom, and Asia-Pacific, subjecting it to an extensive and overlapping matrix of financial, privacy, and technology regulations.

Department, Process & Function

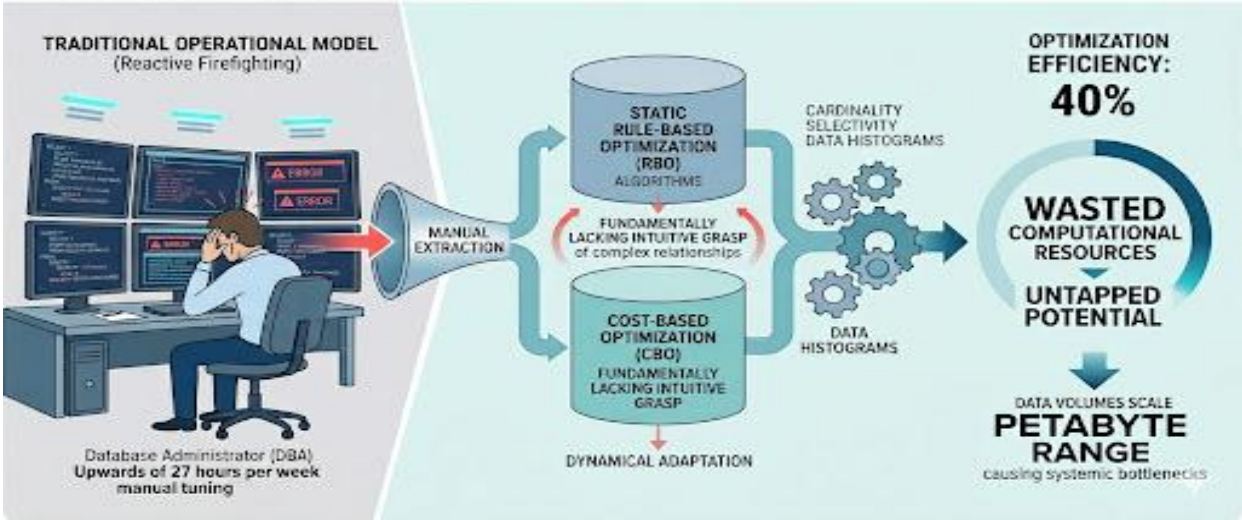
The proposed AI solution automates Oracle database performance tuning within IT/Database Site Reliability Engineering (SRE). In the current environment, DBAs identify and optimize slow SQL queries reactively using native Oracle tools. The future-state pipeline transitions to proactive, AI-driven automation, continuously monitoring databases to detect inefficient queries based on established criteria. Anonymized metadata is sent to a large language model for tuning recommendations, which are mathematically validated by Oracle prior to DBA approval.

This section outlines the strategy for integrating AI into global banking IT operations, with a focus on database performance and SRE. Traditional SQL tuning is reactive and manual, demanding substantial engineering resources but offering diminishing returns as data volumes increase. The proposed Automated SQL Performance Tuning Pipeline continuously scans workloads, identifies resource-intensive queries, sanitizes sensitive information, and leverages external language models for optimization suggestions. Recommendations are validated through Oracle execution plan simulation before implementation. The objectives are to reduce resolution times from days to minutes, improve resilience and latency, enable engineers to prioritize strategic initiatives, and uphold strict compliance standards.

The core problem is the unsustainable manual database management approach, with SREs and DBAs spending over 27 hours weekly on inefficient troubleshooting and relying on outdated algorithms with only 40% effectiveness. This method is inadequate for enterprise-level data growth. The following diagram illustrates the contrast between manual bottlenecks and the optimized future state.



OPERATIONAL DOMAIN ANALYSIS



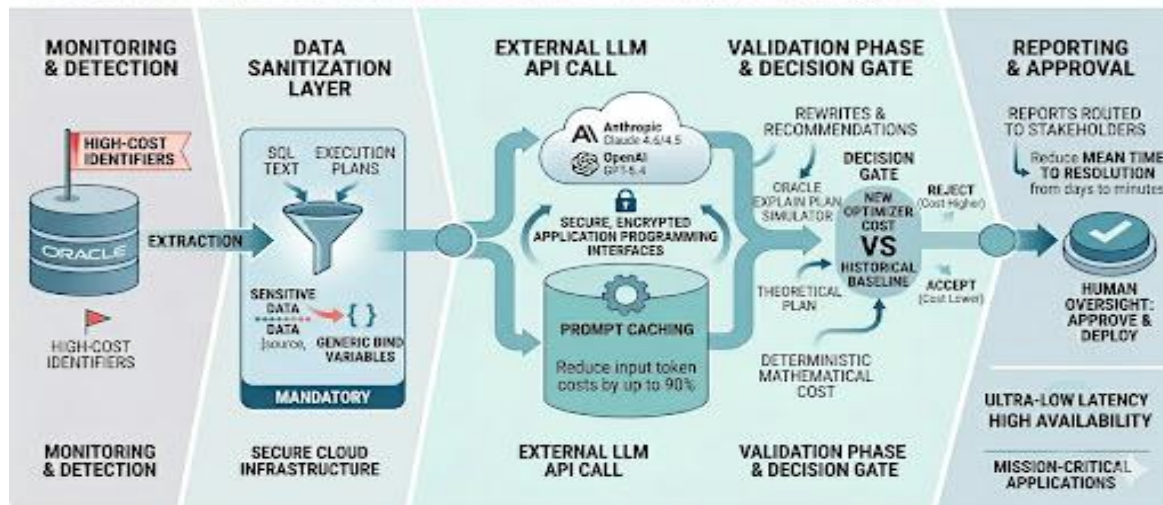
Current vs. Future State

Dimension	Current State	AI-Enabled Future State
Detection	Reactive — ticket-driven	Proactive — continuous monitoring
Analysis	Manual DBA investigation	LLM-generated tuning recommendations
Validation	Manual EXPLAIN PLAN review	Oracle-automated cost comparison
MTTT	Hours to days	Minutes
Audit Trail	Inconsistent documentation	Full PDF report + immutable logs

Automated SQL Performance Tuning Pipeline

This diagram depicts the automated SQL performance tuning pipeline, which systematically identifies, sanitizes, analyzes, validates, and deploys query optimizations. The process begins by extracting high-cost SQL queries and applying mandatory data sanitization to remove literal values. Requests are then routed to external large language model APIs (such as Claude and GPT), followed by mathematical validation through Oracle's Explain Plan simulator. A decision gate objectively compares the cost of the original and optimized queries. The pipeline concludes with structured reporting and a human approval workflow, ensuring rigor and transparency suitable for academic evaluation.

AUTOMATED SQL PERFORMANCE TUNING PIPELINE (Concept Diagram)



2. Technology Choice

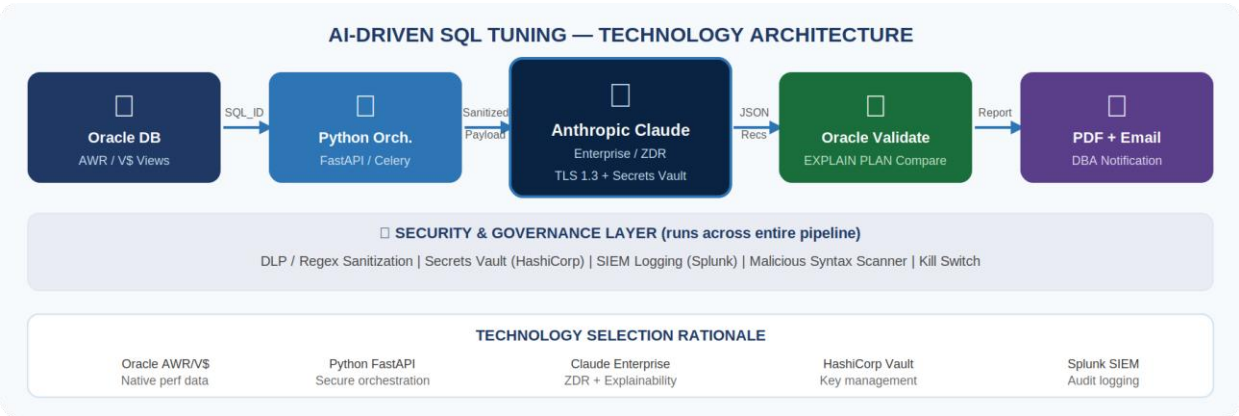
Primary AI System: one of the top Frontier Models

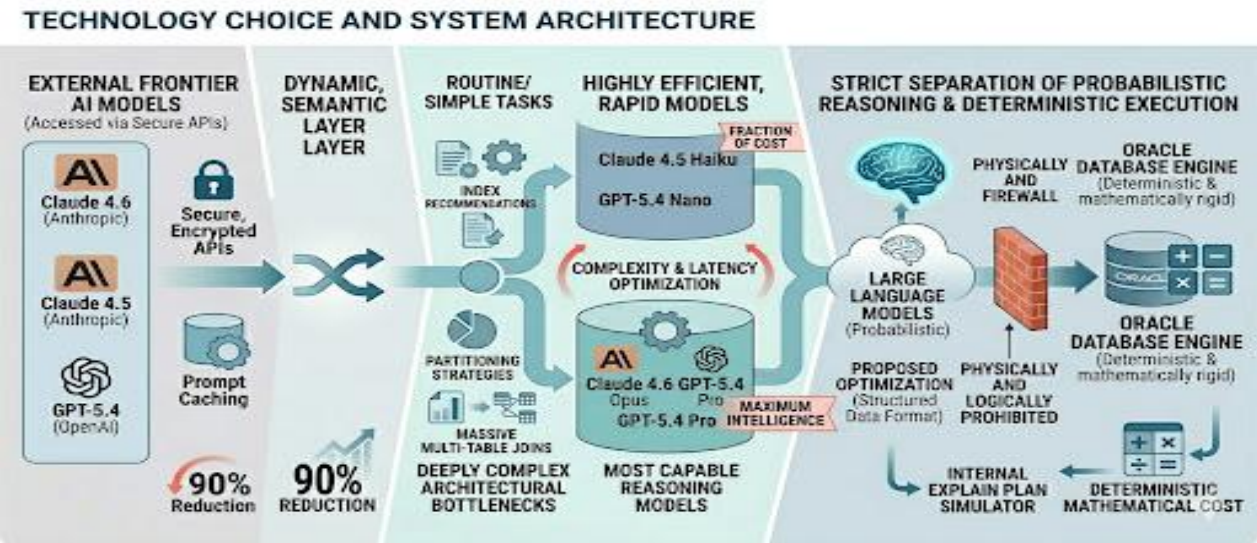
The Bank selects one of the top Frontier models a primary LLM provider for the SQL tuning pipeline based on four decisive factors:

- **Zero Data Retention (ZDR):** Anthropic's Enterprise tier contractually guarantees that API payloads are not retained or used for model training — a non-negotiable requirement under GLBA, GDPR, and the Bank's internal data governance policy.
- **Reasoning Quality:** Claude's extended thinking and chain-of-thought output provides the SQL optimizer rationale required for SR 11-7 model explainability and DBA review.
- **Safety Architecture:** Constitutional AI training reduces the probability of malicious or destructive SQL recommendations being returned in API responses.
- **Enterprise Controls:** SSO, SCIM, role-based permissioning, audit logs, and a Compliance API align directly with FFIEC and NYDFS cybersecurity governance requirements.
- **Ease of integration with on-prem MCP:** framework reusability, ease of implementation

This section outlines the architectural and technological decisions supporting the solution, emphasizing the strategic use of external, enterprise-grade LLMs over proprietary AI development. The hybrid architecture separates probabilistic AI reasoning from deterministic database execution, ensuring AI serves only for analysis and recommendations, not direct execution. Semantic routing dynamically assigns workloads to model tiers based on complexity, optimizing latency and cost by reserving advanced reasoning models for challenging scenarios. All AI-generated outputs undergo mathematical validation via Oracle's explain-plan simulation before deployment. Additional features such as prompt caching, structured payloads, and secure API orchestration enhance scalability, reduce token costs, and maintain predictable performance. This architecture delivers innovative AI reasoning while upholding deterministic guarantees essential in regulated financial environments.

The pipeline's internal logic and security principles are visualized in the accompanying diagram. Semantic routing directs queries to appropriate LLM tiers (Haiku/Nano for simple, Opus/Pro for complex) based on context and cost efficiency. The architecture enforces strict separation between external AI reasoning and internal Oracle execution, ensuring all AI proposals are mathematically validated before implementation. Secure APIs and prompt caching further reinforce the system's integrity and efficiency.





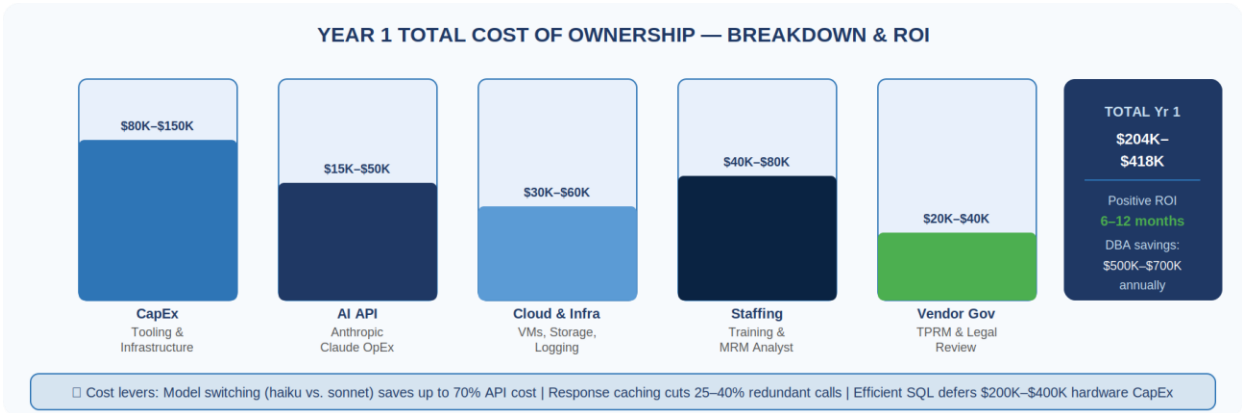
Supporting Technology Stack

Component	Technology	Purpose
LLM API	Any Frontier Models	Tuning recommendations & reasoning
Orchestration with MCP	Python (FastAPI / Celery), MCP	Pipeline control, sanitization, parsing, framework reusability, ease of implementation
Database	Oracle DB (AWR / V\$ views)	SQL extraction, plan comparison
Secrets Vault	HashiCorp Vault / AWS Secrets Mgr	API key management and rotation
SIEM / Logging	Splunk / Elastic SIEM	Centralized audit logging, anomaly alerts
DLP / Redaction	Python regex + Microsoft Presidio	PII scrubbing before API call

3. Cost Considerations

Total Cost of Ownership — Year 1 Estimate

This section provides a comprehensive total cost of ownership analysis for deploying and maintaining the AI-driven tuning pipeline within a global financial institution. Costs are categorized into capital expenditures for initial development and integration, operational expenditures primarily related to API usage and cloud infrastructure, and ongoing staffing and maintenance. Notably, the largest long-term investment is in specialized personnel, such as AI engineers, security experts, and data privacy professionals—a factor often underestimated in AI projects. The analysis also outlines strategies to reduce operational expenses, including prompt caching, batch processing, and model tiering. Overall, despite the significant initial and recurring costs, the analysis demonstrates clear economic value through infrastructure cost savings, enhanced productivity, and reduced operational risk, with industry benchmarks suggesting positive returns within a defined multi-year timeframe.



Cost Category	Description	Estimated Range
Capital Expenditure (CapEx)	SIEM/PAM tooling, vault infrastructure, secure API gateway, DLP integration	\$80,000–\$150,000 one-time
AI API (OpEx)	Anthropic Claude API – ~\$0.01–\$0.16 per call; 10k calls/day est.	\$15,000–\$50,000 / year
Cloud & Infrastructure	Orchestration VMs, encrypted storage, logging/monitoring stack	\$30,000–\$60,000 / year
Staffing & Training	MRM analyst, DBA upskilling, SecOps AI threat training, DPO advisory	\$40,000–\$80,000 / year
Vendor Governance	Third-party risk assessments, ZDR legal review, audit rights	\$20,000–\$40,000 / year
Contingency (10%)	Buffer for scope changes, regulatory updates, pilot overruns	\$18,500–\$38,000
Total Estimated TCO (Yr 1)		\$203,500–\$418,000

Cost Optimisation Levers

- **Model switching:** Route high-volume, low-complexity queries to claude-haiku (approx. \$0.003/call) and reserve claude-sonnet for complex analytical prompts — reducing API OpEx by up to 70%.
- **Response caching:** Cache LLM outputs for identical SQL patterns; estimated 25–40% reduction in redundant API calls over time.
- **Token discipline:** Strict prompt templates cap input tokens at ~500 and output at ~1,000, preventing runaway spend; a hard daily API budget ceiling auto-disables the key if breached.

- Deferred hardware CapEx: Efficient SQL reduces CPU/disk utilisation, deferring infrastructure upgrades — estimated \$200,000–\$400,000 in deferred capital spend over 3 years.

ROI Summary

Based on internal benchmarks, a 40% DBA workload reduction on SQL tuning tasks (at average fully-loaded cost of \$120/hr) across a team of 10 DBAs yields approximately \$500,000–\$700,000 in annual productivity savings — producing positive ROI within 6–12 months of Phase 2 deployment.

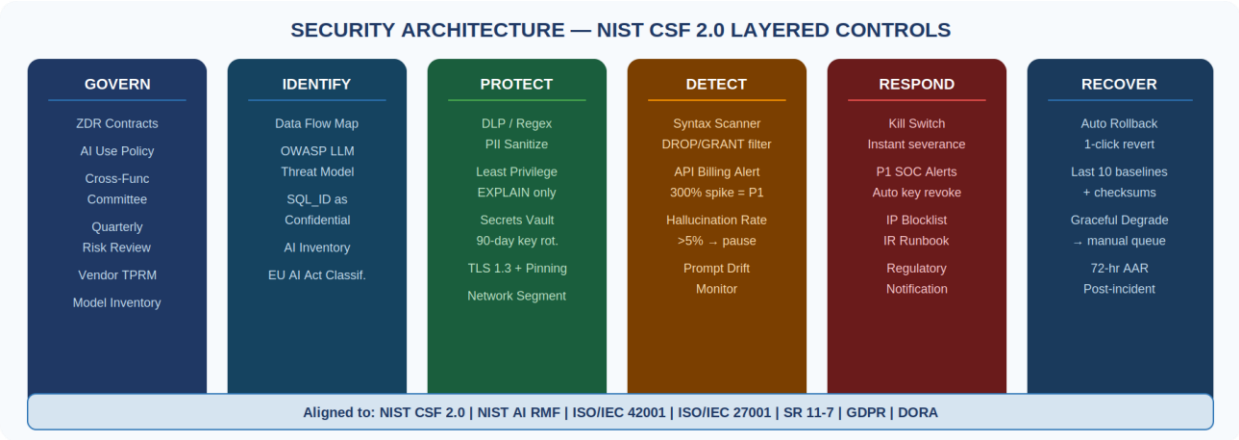
4. Security Plan

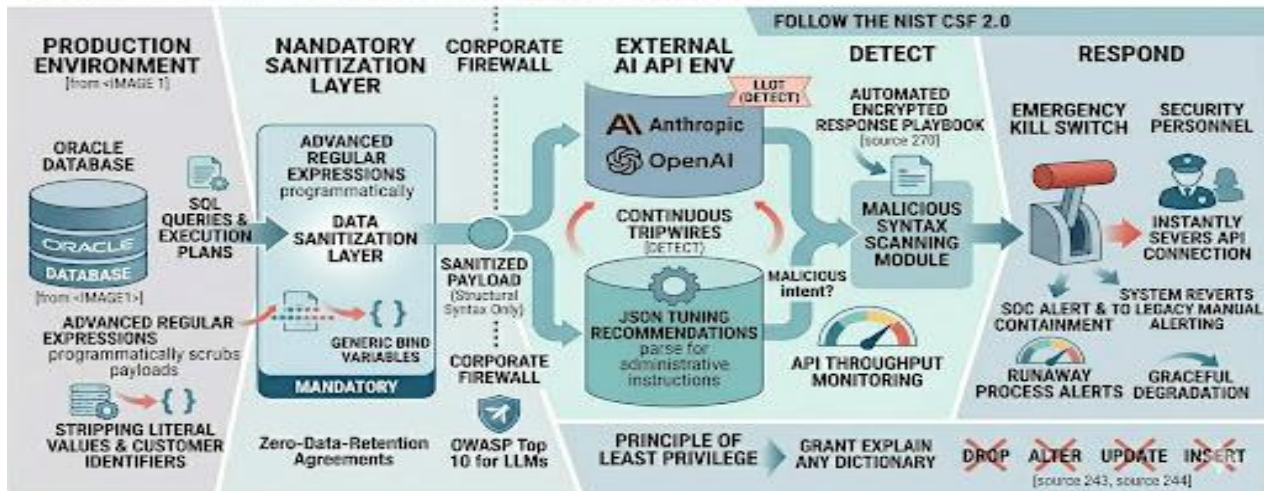
The security architecture is organized according to the six core functions of the NIST Cybersecurity Framework (CSF) 2.0, and is further strengthened by the NIST AI Risk Management Framework and ISO/IEC 42001/27001 standards.

This section presents a security-first approach, explicitly aligned with the NIST Cybersecurity Framework and NIST AI Risk Management Framework, to address risks unique to generative AI. Threats such as insecure AI-generated code, prompt injection, data leakage, and uncontrolled automation are identified, with layered controls implemented to mitigate them. Key safeguards include strict least-privilege database access to prevent destructive actions, mandatory data sanitization to remove sensitive information prior to external processing, and automated scanning of AI outputs for unauthorized or malicious instructions. Continuous monitoring of API usage, behavioral anomalies, and cost spikes enables rapid detection and response, supported by an emergency kill switch to immediately sever external AI connectivity if necessary. The design ensures that, even in cases of AI hallucinations, compromised credentials, or external attacks, the system cannot modify production data without deterministic validation and explicit governance oversight.

As a result, production systems are protected from direct impact without rigorous validation and security oversight.

The accompanying diagram illustrates the multi-layered defense architecture, structured in accordance with NIST CSF 2.0 and ISO standards. Core elements include an automated Data Sanitization Layer that replaces sensitive data with bind variables, enforcement of the Principle of Least Privilege at the database kernel level, and Malicious Syntax Scanning for input and output validation. The architecture also features continuous monitoring and an Emergency Kill Switch to promptly disconnect external LLM API connections in the event of a breach or uncontrolled process.



SECURITY PLAN & CYBER RESILIENCE FRAMEWORK**Govern & Identify**

- Zero-Data-Retention (ZDR) contracts executed with all LLM providers before any API call is made.
- AI Acceptable Use Policy: raw, unsanitized production data submission is a terminable offence; annual attestation required for all pipeline users.
- Full Data Flow Map documented for GDPR and DORA compliance: Monitoring Tool → Python Orchestrator → LLM API → Oracle Validation → PDF Report.
- OWASP Top 10 for LLMs threat model: Prompt Injection (LLM01), Insecure Output Handling (LLM02), and Supply Chain Vulnerabilities (LLM05).

Protect

- Data Sanitization Layer: Python + Microsoft Presidio scrubs all literal values (PII, account numbers, SSNs) from SQL text before any payload leaves the network, replacing them with bind variables (e.g., WHERE email = :bind_var).
- Principle of Least Privilege: DB automation account restricted to GRANT EXPLAIN ANY DICTIONARY only — blocked from DROP, ALTER, UPDATE, INSERT, GRANT at the Oracle kernel level.
- Secrets Vault: API keys in HashiCorp Vault with automatic 90-day rotation; TLS 1.3 enforced on all API transit; certificate pinning recommended.

Detect, Respond & Recover

- Malicious Syntax Scanner: every LLM JSON response parsed for dangerous DDL/DML keywords (DROP, TRUNCATE, GRANT, ALTER) before Oracle ingests it.
- API Billing Monitors: token usage spike >300% within one hour triggers a P1 alert and auto-disables the API key.
- Emergency Kill Switch: centralized feature flag instantly severs the orchestration-to-LLM connection, degrading to manual DBA alerting.
- Automated Rollback: one-click script reverts SQL baseline to the prior known-good state; last 10 baselines retained with checksummed integrity validation.

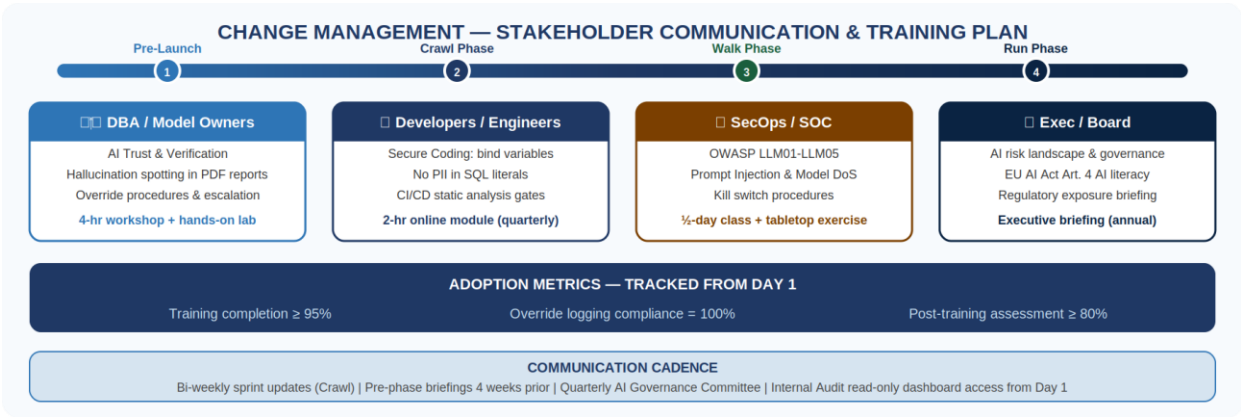
5. Change Management and Training

Stakeholder Communication Plan

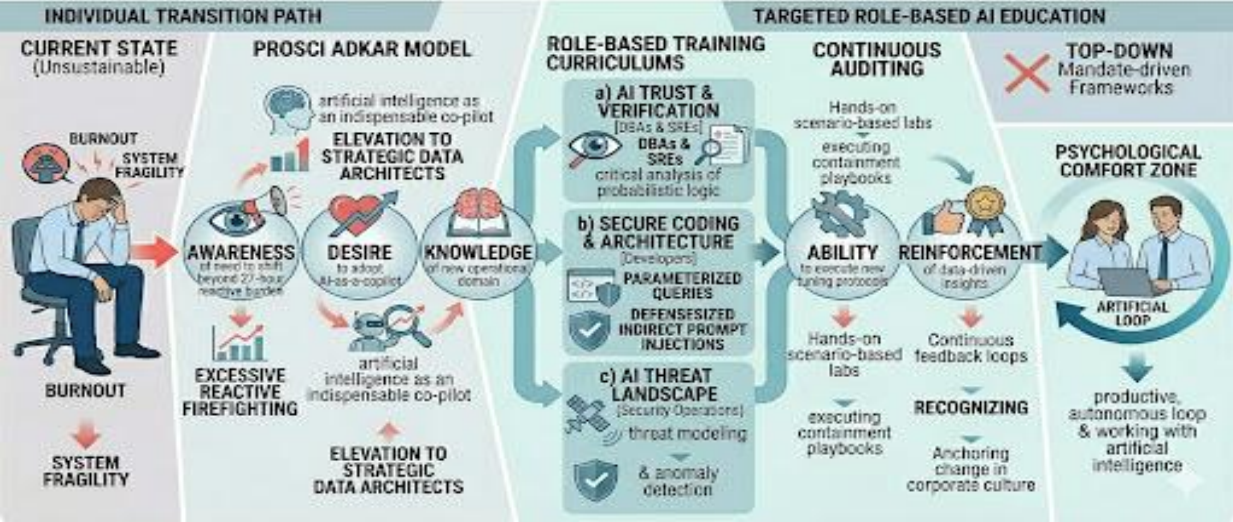
Successful implementation requires a well-defined communication strategy tailored to distinct stakeholder groups during each phase of rollout. This approach promotes transparency, fosters trust, and drives measurable adoption across all organizational levels.

This section addresses the human and organizational aspects of deploying autonomous AI systems within engineering teams. Applying the Prosci ADKAR change management framework, it guides individuals through awareness, desire, knowledge, ability, and reinforcement, emphasizing that effective AI adoption is rooted in trust and competence rather than mandates. The strategy positions AI as a collaborative tool that reduces repetitive tasks, directly alleviating concerns about job displacement and loss of control. Role-specific training programs for database engineers, developers, and security teams focus on AI trust verification, secure prompt engineering, and threat detection. Reinforcement mechanisms—including continuous feedback, hands-on validation, and recognition of successful AI-assisted outcomes—anchor adoption and ensure sustained engagement and cultural alignment with the new operational model.

The accompanying diagram outlines the people transition strategy, utilizing the Prosci ADKAR model and role-based training in place of traditional top-down mandates. Leadership initiates awareness and desire for AI adoption, shifting the focus from replacement anxiety to collaborative support. The knowledge and ability phases deliver targeted AI training for DBAs/SREs, developers, and security operations, enabling critical review of outputs and secure coding practices. The ADKAR framework connects these efforts to a productive, autonomous partnership with AI.



CHANGE MANAGEMENT STRATEGY & TARGETED TRAINING CURRICULUM



- Executive / Board: Quarterly AI governance committee briefings covering risk posture, KPI performance, regulatory developments, and vendor oversight updates.
- DBA / Engineering Teams: Bi-weekly sprint reviews during pilot; transition briefings 4 weeks prior to each phase advancement.
- Internal Audit & Compliance: Pre-pilot walkthrough of controls architecture, evidence packages, and audit trail design; read-only dashboard access from Day 1.
- Legal & Privacy: Engaged at inception for ZDR contract review, DPIA completion, and cross-border transfer mechanism approval.

Role-Based Training Programme

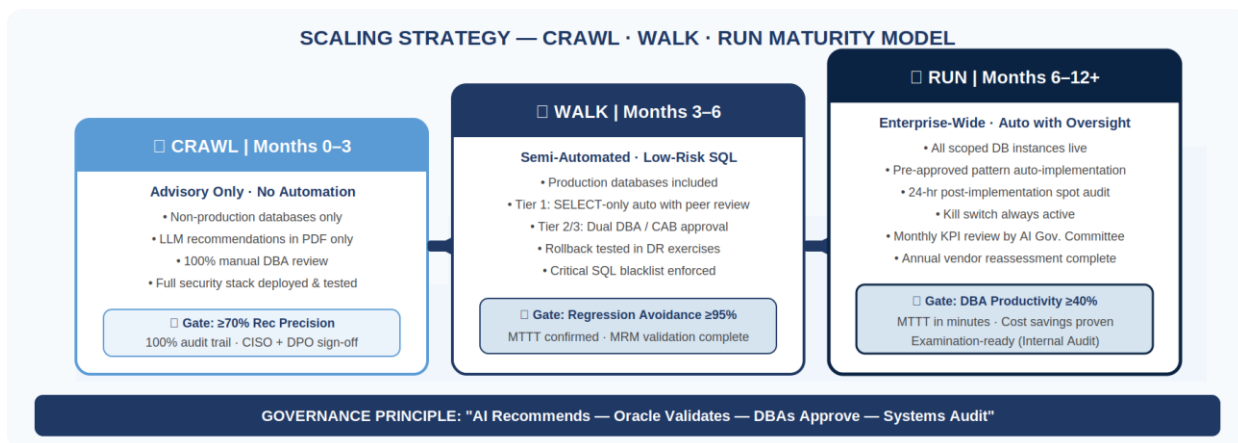
Role	Training Focus	Delivery & Cadence
DBAs / Model Owners	AI Trust & Verification: LLMs are probabilistic — reviewing PDF reports for hallucinations; override procedures; escalation paths.	4-hour workshop + hands-on lab. Annual refresh.
Developers / Automation Eng.	Secure coding: parameterised queries, bind variables, no PII in literals. Static analysis in CI/CD pipeline.	2-hour online module. Quarterly update.
SecOps / SOC Analysts	OWASP Top 10 for LLMs: Prompt Injection (LLM01), Model DoS (LLM04), Supply Chain (LLM05). Kill switch.	Half-day classroom + tabletop exercise. Semi-annual.
Legal & Compliance	Regulatory obligations: SR 11-7, GDPR, EU AI Act, DORA; ZDR contract obligations; cross-border transfer rules.	2-hour briefing. Annual update.
Senior Management / Board	AI risk landscape, governance responsibilities, EU AI Act Art. 4 AI literacy, strategic implications.	Executive briefing deck. Annual session.

6. Scaling Strategy — Crawl, Walk, Run

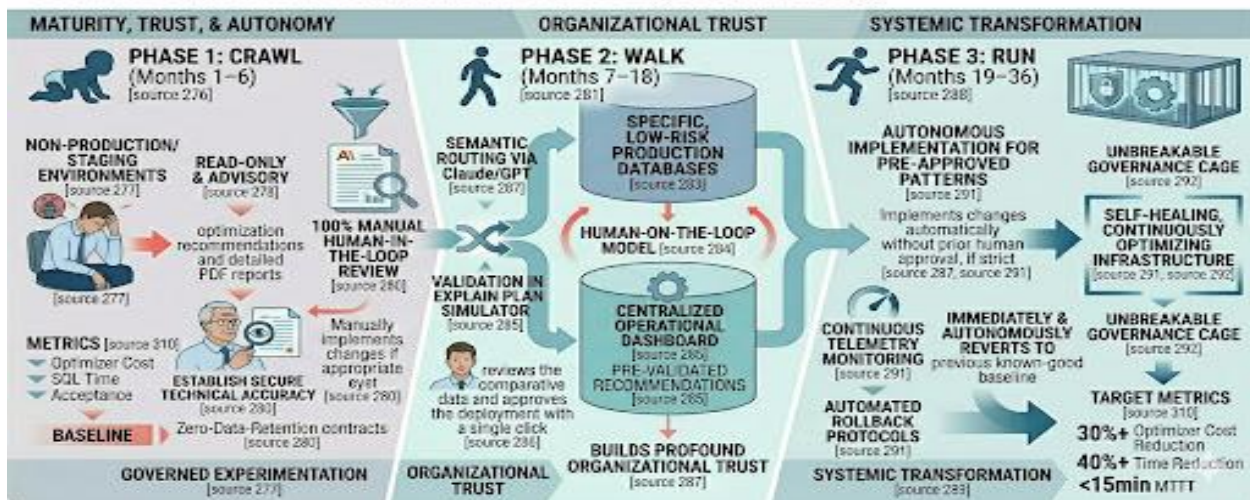
The implementation utilizes a phased maturity model, progressively expanding the scope of automation as controls are validated and confidence is established among regulators, auditors, and engineering teams.

This section outlines a structured, multi-year scaling strategy based on the Crawl, Walk, Run maturity model to ensure safe and governed AI adoption. In the Crawl phase, operations are limited to non-production environments with rigorous human-in-the-loop oversight for validating technical accuracy, security controls, and data sanitization. The Walk phase introduces AI recommendations into selected low-risk production systems, employing human-on-the-loop workflows where automatic validation is complemented by streamlined approval processes. The Run phase permits limited autonomous execution for pre-approved query patterns that consistently meet deterministic validation criteria, reinforced by automated rollback mechanisms to promptly address any unanticipated degradation. This sequential approach balances innovation and risk management, enabling increased autonomy and trust as empirical evidence and governance maturity are demonstrably achieved.

The accompanying diagram depicts the 24–36 month phased deployment roadmap—Crawl, Walk, Run—highlighting progressive autonomy: from fully manual human-in-the-loop review, to human-on-the-loop validation and approval, and ultimately to autonomous implementation for pre-approved patterns with rollback capability. It demonstrates how organizational trust is established through mathematical verification of AI proposals and strict enforcement of zero-data retention agreements across all environments. Each phase sets defined benchmarks to ensure measurable progress.



SCALING STRATEGY: THE MATURITY MODEL (Concept Roadmap)



Phase 1 — Crawl (Months 0–3): Advisory Only

- Scope: Non-production databases only; advisory mode — LLM recommendations surfaced in PDF reports, zero automated implementation.
- Controls: Full data sanitization layer, ZDR contracts, DLP scanning, least privilege accounts, secrets vault, SIEM logging — all deployed and tested.
- Human Oversight: 100% DBA manual review of every recommendation before any consideration of implementation.
- Success Gate: $\geq 70\%$ recommendation precision; 100% audit trail completeness; zero sanitization failures; CISO and DPO sign-off.

Phase 2 — Walk (Months 3–6): Semi-Automated for Low-Risk SQL

- Scope: Production databases included; Tier 1 automation permitted for pre-approved, read-optimisation-only SQL patterns.
- Controls: Dual DBA approval for Tier 2 and Tier 3 changes; blacklist of critical application SQL IDs; automated rollback fully tested in DR exercises.
- Success Gate: Regression avoidance rate $\geq 95\%$; MTTT reduction confirmed; independent MRM validation complete; no P1 security incidents.

Phase 3 — Run (Months 6–12+): Expanded Autonomous Operation

- Scope: Enterprise-wide deployment across all scoped database instances; limited auto-implementation for pre-approved patterns with rollback automation.
- Controls: Full governance suite operational; quarterly DR drills; vendor annual reassessment complete; post-incident AARs feeding continuous improvement.
- Success Gate: DBA productivity gain $\geq 40\%$; MTTT in minutes; infrastructure cost savings demonstrable; regulatory examination readiness confirmed.

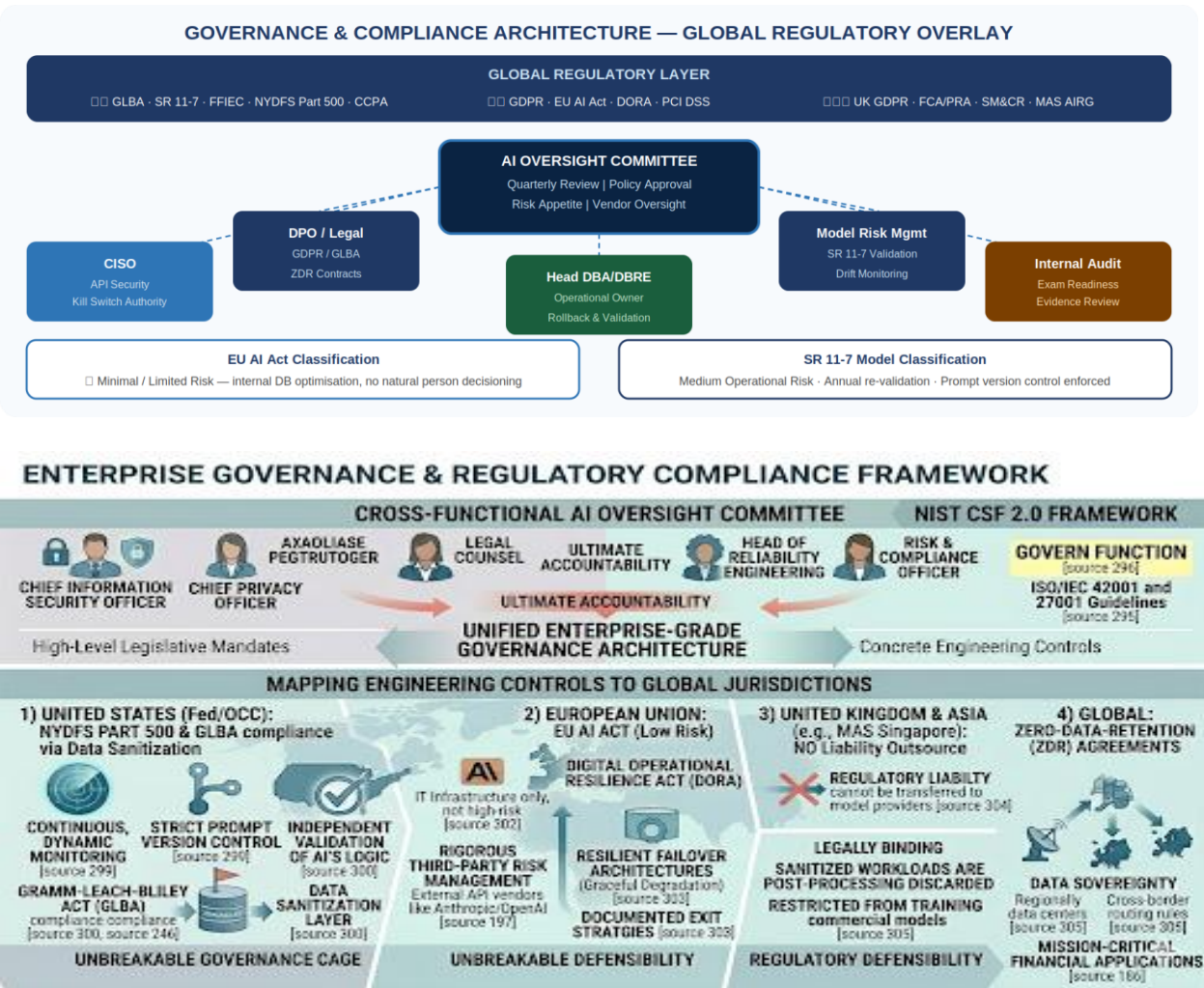
"AI Recommends — Oracle Validates — DBAs Approve — Systems Audit"

7. Governance and Compliance

Governance is structured across five pillars: the Cross-Functional AI Oversight Committee, AI use-case inventory, model risk management, regulatory compliance, and third-party vendor governance.

This section presents a comprehensive governance framework designed to ensure regulatory compliance across U.S., European, and international jurisdictions. Technical and operational controls are mapped to regulatory standards, including SR 11-7 model risk management, GLBA, GDPR, DORA, and global banking mandates. Oversight is managed by a cross-functional AI governance committee, which is responsible for accountability, third-party risk management, and policy enforcement. The framework incorporates zero-data-retention contracts with AI vendors, regional data processing controls to address data sovereignty, and continuous monitoring to mitigate model drift and vendor changes. Integrating governance into system design and operations ensures regulatory defensibility and supports scalable, cross-border AI deployment.

The accompanying diagram depicts an enterprise-grade governance architecture, aligning engineering controls with global jurisdictions (US, EU, UK, Singapore) through the NIST CSF 2.0 framework and ISO standards. Key elements include the Cross-Functional AI Oversight Committee (CISO, Privacy Officer, Legal, Head of DRE, Risk & Compliance), robust third-party risk management adhering to DORA for external API vendors, and mandatory Zero-Data-Retention agreements. The architecture enforces data sovereignty and implements continuous dynamic monitoring, fulfilling SR 11-7 Model Risk Management requirements for US banking. It also clarifies that liability for external models cannot be outsourced. All diagram labels are retained, with bracketed sources omitted.



Cross-Functional AI Oversight Committee

- CISO: API security architecture, TLS enforcement, SOC 2 vendor review, kill switch authority.
- DPO / Legal: GDPR/CCPA/GLBA compliance, ZDR contract language, DPIA completion, cross-border transfer mechanism approval.
- Head of DBA / DBRE: Operational owner; validation logic; restricted DB accounts; rollback; quarterly DR testing.
- Model Risk Management: Independent validation, model inventory, drift monitoring, change control for prompt/model updates.
- Internal Audit: Periodic assurance over controls, evidence review, examination readiness.

Applicable Regulatory Compliance Matrix

Regulation / Standard	Jurisdiction	Key Compliance Action for This Project
GLBA / FTC Safeguards Rule	U.S.	Data minimization, DLP, encryption, no PII in prompts
SR 11-7 Model Risk Mgmt	U.S. Banking	Model inventory, validation, human oversight, drift monitoring
Interagency TPRM (OCC/FRB/FDIC)	U.S. Banking	Vendor due diligence, ZDR contracts, exit strategy
NYDFS Part 500	New York	Cyber governance, AI vendor controls, annual certification
GDPR / UK GDPR	EU / UK	DPIA, SCCs, data minimization, retention schedules
EU AI Act	EU	AI inventory, risk classification, human oversight
DORA	EU Financial	ICT resilience, third-party oversight, incident reporting
PCI DSS	Global	Segment PCI systems; no payment data in prompts or logs
CCPA / CPRA	California	Minimize personal info; define retention and access controls

EU AI Act & SR 11-7 Classification

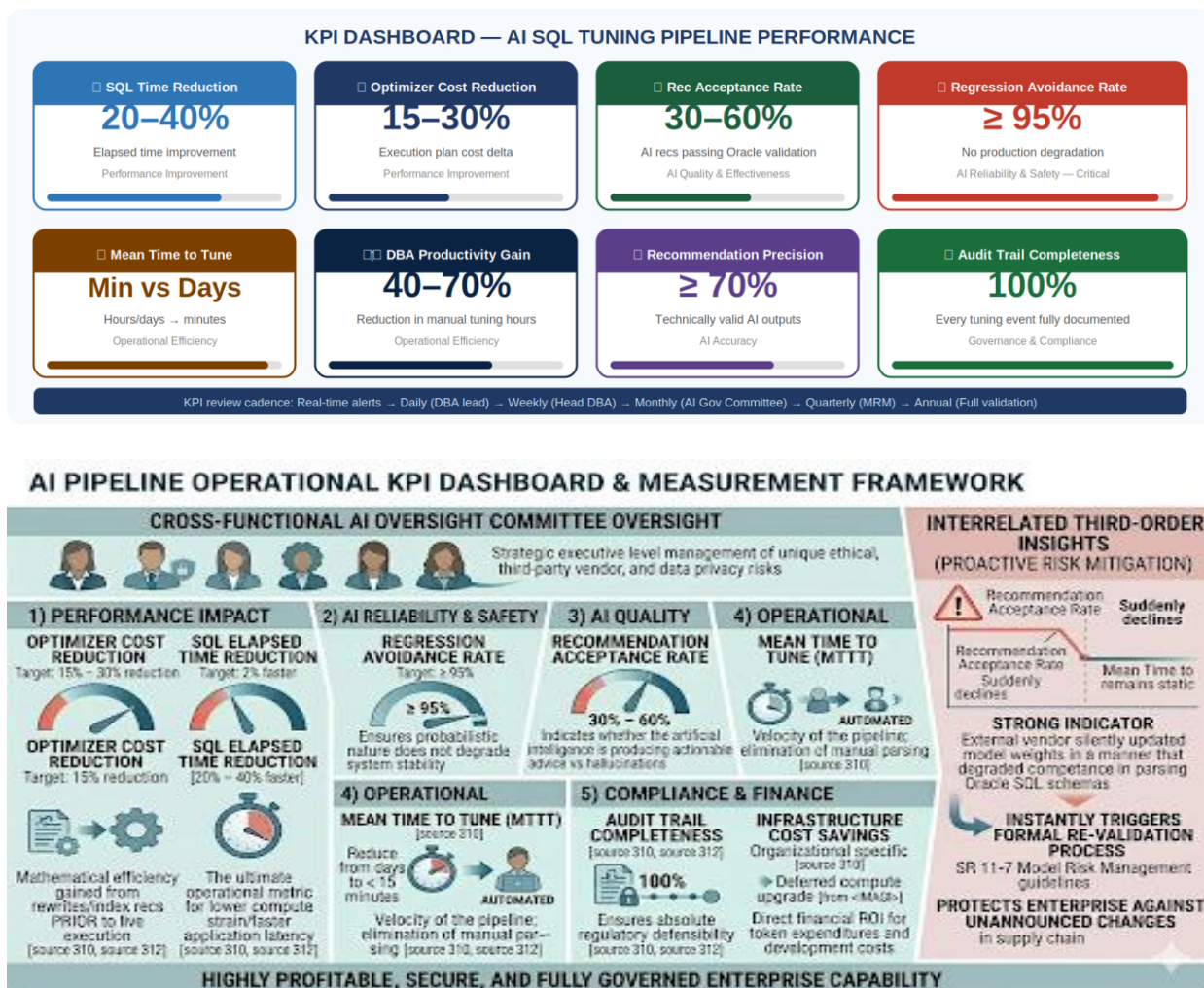
AutoTune AI is formally classified as Minimal/Limited Risk under the EU AI Act (internal DB optimisation, no natural person decisioning, Art. 6(3) procedural task exclusion). Under SR 11-7, the system is classified as Medium Operational Risk / Elevated Data-Handling Risk / Low Customer-Harm Risk. Both classifications are documented, reviewed annually, and held in the enterprise AI inventory.

8. Key Performance Indicators (KPIs)

The KPI framework spans four dimensions — Performance Improvement, AI Quality & Safety, Operational Efficiency, and Governance & Compliance — ensuring that the AI system delivers measurable value while remaining safe and auditable at every phase of maturity.

This section presents a robust KPI framework designed to evaluate the effectiveness, safety, and financial impact of the AI tuning pipeline. Key metrics include performance improvement (optimizer cost and execution time reduction); AI quality and reliability (recommendation acceptance and regression avoidance rates); operational efficiency (mean time to tune); financial value (infrastructure cost savings); and compliance (audit trail coverage). The framework enables ongoing oversight by quantifying governance and risk principles, facilitating early detection of model degradation, vendor changes, or systemic risk. Collectively, these KPIs ensure the AI system delivers sustained business value while adhering to defined safety, compliance, and performance standards.

The accompanying diagram delineates five operational KPI categories, each with target benchmarks: Performance Impact (Optimizer Cost, SQL Time Reduction), AI Reliability & Safety (Regression Avoidance Rate), AI Quality (Acceptance Rate), Operational Efficiency (Mean Time to Tune—reduce days to under 15 minutes), and Compliance/Finance (Audit Trail Completeness, Infrastructure Cost Savings). The visualization emphasizes interrelated insights and advanced analysis, exemplified by a scenario where declining 'Recommendation Acceptance Rate' with a static 'Mean Time to Tune' signals model drift due to an external supplier update. This triggers immediate re-validation in accordance with SR 11-7 Model Risk Management guidelines. All other descriptions serve as direct category labels.



KPI Name	Category	Measurement Formula	Target Benchmark
SQL Elapsed Time Reduction	Performance Improvement	$(\text{Original} - \text{New}) / \text{Original} \times 100$	20–40%
Optimizer Cost Reduction	Performance Improvement	Cost delta vs original plan	15–30%
Recommendation Acceptance Rate	AI Quality	$\text{Approved} / \text{Total AI Recs} \times 100$	30–60%
Regression Avoidance Rate	AI Safety	$\text{Successful} / \text{Total Changes} \times 100$	≥95%
Mean Time to Tune (MTTT)	Operational Efficiency	SQL Detection → Validation time	Minutes (vs hours)
DBA Productivity Gain	Operational Efficiency	Baseline hours – Post-AI hours	40–70% reduction
Recommendation Precision	AI Accuracy	$\text{Valid Recs} / \text{Total Outputs} \times 100$	≥70%
Audit Trail Completeness	Governance & Compliance	$\text{Fully Documented Events} / \text{Total} \times 100$	100%

Monitoring & Review Cadence

- Real-time: API billing monitors, malicious syntax alerts, efficacy anomaly detection — automated and continuous.
- Daily: SQL runtime and cost reduction metrics reviewed by DBA team lead via KPI dashboard.
- Weekly: Recommendation acceptance rate and regression avoidance reviewed by Head of DBA/DBRE.
- Monthly: Full KPI scorecard reviewed by AI Governance Committee; exception reporting to Technology Risk.
- Quarterly: Independent model performance review; DR rollback exercise; vendor reassessment checkpoint.
- Annually: Full model re-validation; regulatory compliance self-assessment; enterprise AI inventory update.

What Success Looks Like

- SQL elapsed time declining quarter-over-quarter as AI tuning quality improves with each re-validation cycle.
- Regression avoidance rate sustained above 95%, confirming production safety of automated changes.
- DBA workload on routine SQL tuning reduced by 40–70%, with senior DBAs redirected to architectural work.
- Audit trail completeness at 100%, providing regulators and Internal Audit with examination-ready evidence on demand.
- Infrastructure cost trend flattening or declining as efficient SQL reduces CPU, memory, and disk utilisation.

CONCLUSION

The deployment of AI-driven SQL performance tuning within a global financial institution represents a strategically sound, measurably beneficial, and regulatory-defensible investment. By grounding the implementation in NIST CSF 2.0, the NIST AI RMF, ISO/IEC 42001, and ISO/IEC 27001, and by adopting a crawl-walk-run maturity model with rigorous human oversight, the Bank ensures that AI functions as an amplifier of DBA expertise rather than a replacement for it.

The governance principle is clear: AI recommends, Oracle validates, humans approve, and systems audit. Every action is traceable, every change is reversible, and every regulatory obligation from GLBA and SR 11-7 to GDPR, DORA, and the EU AI Act is addressed through concrete, documented controls. This is not AI as a technology experiment — it is AI as a formally governed, audit-ready business capability.
